Evidências Pré-Geradas do Pipeline Inicial Clube Aurora

Material de Apoio Oficial para o Nível 1 (Teórica Guiada)

> **Aviso Importante para os Alunos do Nível 1:**
> Se você escolheu o **Nível 1 (Teórica Guiada)**, você **não precisa** instalar Docker, Python nem rodar pipelines no GitHub Actions.
> Este documento reúne os **extratos reais e autênticos** dos relatórios emitidos pelas ferramentas de segurança do projeto (`Gitleaks` , `Hadolint` , `Trivy FS` , `Semgrep SAST` , `Semgrep Compose` , `Trivy Image` e `OWASP ZAP`) na execução do repositório vulnerável original (`aurora/`). Utilize estes dados para embasar as respostas do seu relatório `aluno/TEMPLATE_TG.md` .

---

1. Relatório Gitleaks (Detecção de Segredos - Falha F1)

- **Arquivo Analisado:** `.env` (rastreado e commitado)
- **Origem da Evidência:** `logs_execucao/vulneravel/vuln_static.md` , linhas 244 a 254
- **Extrato Real do Log:**

```
Finding:     ADMIN_INITIAL_TOKEN=eyJhZG1pbiI6dHJ1ZSwidXNlciI6ImFybWFuZG8ifQ.compromised
Secret:      eyJhZG1pbiI6dHJ1ZSwidXNlciI6ImFybWFuZG8ifQ.compromised
RuleID:      generic-api-key
Entropy:     4.780273
File:        /src/.env
Line:        7
Fingerprint: /src/.env:generic-api-key:7

6:23AM WRN leaks found: 1
##[error]Process completed with exit code 1.
```

- **Diagnóstico Técnico:**
  O scanner de credenciais identificou um token estático administrativo commitado no arquivo `.env` . Como o `.gitignore` não continha a entrada `.env` , a credencial tornou-se pública para qualquer pessoa com acesso ao repositório Git.

---

2. Relatório Hadolint (Linter do Dockerfile - Falha F4)

- **Arquivo Analisado:** `Dockerfile` (raiz do repositório)
- **Origem da Evidência:** `logs_execucao/vulneravel/vuln_static.md` , linha 187
- **Saída Estruturada do Hadolint:**


```
{
  "line": 6,
  "code": "DL3007",
  "message": "Using latest is prone to errors if the image will ever update. Pin the version explicitly to
  "column": 1,
  "file": "Dockerfile",
  "level": "warning"
}
```

```
```

- **Diagnóstico Técnico:**
  O linter identificou a regra `DL3007` na linha 6 (`FROM python:latest`). O uso da tag mutável `:latest` quebra a reprodutibilidade da esteira e importa uma imagem desnecessariamente pesada e imprevisível.
  (Nota de auditoria: além da regra DL3007 apontada pelo linter, a inspeção visual do `Dockerfile` revela a ausência de usuário não-root, ausência de `HEALTHCHECK` e falta de compilação multi-stage).

---

3. Relatório Trivy Filesystem (SCA de Dependências Python - Falha F2)

- **Arquivo Analisado:** `requirements.txt`
- **Origem da Evidência:** `logs_execucao/vulneravel/vuln_static.md` , linhas 324 a 345
- **Extrato Real do Log:**

```
requirements.txt (pip)
----------------------
Total: 10 (HIGH: 10, CRITICAL: 0)


 Library   Vulnerability   Severity  Status  Installed Version  Fixed Version

 gunicorn  CVE-2024-1135   HIGH      fixed   20.1.0             22.0.0          python-gunicorn: HTTP Requ
           CVE-2024-6827   HIGH      fixed   20.1.0             22.0.0          gunicorn: HTTP Request Smu
 urllib3   CVE-2023-43804  HIGH      fixed   1.26.5             2.0.6, 1.26.17  python-urllib3: Cookie req
 urllib3   CVE-2025-66418  HIGH      fixed   1.26.5             2.6.0           urllib3: Unbounded decompr
 urllib3   CVE-2025-66471  HIGH      fixed   1.26.5             2.6.0           urllib3: Streaming API imp
 urllib3   CVE-2026-21441  HIGH      fixed   1.26.5             2.6.3           urllib3: Safeguard bypass
 urllib3   CVE-2026-44431  HIGH      fixed   1.26.5             2.7.0           urllib3: Information disc
 urllib3   CVE-2026-97687  HIGH      fixed   1.26.5             2.8.0           urllib3: Traffic intercept
 urllib3   CVE-2026-97689  HIGH      fixed   1.26.5             2.8.0           urllib3: Denial of Service
 werkzeug  CVE-2024-34069  HIGH      fixed   2.2.3              3.0.3           werkzeug: Routing parse cr

##[error]Process completed with exit code 1.
```

- **Diagnóstico Técnico:**
  O scanner de Software Composition Analysis (SCA) reprovou a esteira com **10 vulnerabilidades de severidade HIGH** em bibliotecas externas desatualizadas, detalhando a versão mínima corrigida para cada uma delas.

---

4. Relatório Semgrep SAST (Análise Estática de Código - Falhas F3 e F4)

- **Arquivo Analisado:** `aurora/app/db.py` (linha 102)
- **Origem da Evidência:** `logs_execucao/vulneravel/vuln_static.md` , linhas 555 a 580
- **Extrato Real do Log:**

```
 2 Code Findings


    /src/app/db.py
     python.lang.security.audit.formatted-sql-query.formatted-sql-query
          Detected possible formatted SQL query. Use parameterized queries instead.
```

```
          Details: https://sg.run/EkWw
          102 rows = get_db().execute(query).fetchall()

    python.sqlalchemy.security.sqlalchemy-execute-raw-query.sqlalchemy-execute-raw-query
          Avoiding SQL string concatenation: untrusted input concatenated with raw SQL query can result in
          Injection. In order to execute raw query safely, prepared statement should be used.
          Details: https://sg.run/2b1L
          102 rows = get_db().execute(query).fetchall()

Ran 290 rules on 5 files: 2 findings.
##[error]Process completed with exit code 1.
```

- **Diagnóstico Técnico:**
  O Semgrep flagrou uma vulnerabilidade crítica de **SQL Injection** provocada por interpolação direta de parâmetros de busca via f-string (`f"SELECT * FROM clients WHERE full_name LIKE '%{name}%' ORDER BY id"`), abortando o processo com `exit code 1` .

---

5. Relatório Semgrep Compose (Segurança de IaC - Falha F7)

- **Arquivo Analisado:** `aurora/docker-compose.yml` (linhas 7 e 15)
- **Origem da Evidência:** `logs_execucao/vulneravel/vuln_static.md` , linhas 681 a 707
- **Extrato Real do Log:**

```
 2 Code Findings


    /src/docker-compose.yml
     yaml.docker-compose.security.privileged-service.privileged-service
          Service 'aurora-api' is running in privileged mode. This grants the container the equivalent of
          capabilities on the host machine. Remove the 'privileged' key to disable this capability.
          Details: https://sg.run/AlX0
          7 privileged: true

     yaml.docker-compose.security.exposing-docker-socket-volume.exposing-docker-socket-volume
          Exposing host's Docker socket to containers via a volume. The owner of this socket is root. Givi
          someone access to it is equivalent to giving unrestricted root access to your host. Remove
          'docker.sock' from volumes to prevent this.
          Details: https://sg.run/O14b
          15   - /var/run/docker.sock:/var/run/docker.sock

Ran 6 rules on 1 file: 2 findings.
##[error]Process completed with exit code 1.
```

- **Diagnóstico Técnico:**
  A configuração de infraestrutura como código (IaC) concedeu privilégios excessivos ao contêiner (`privileged: true`), além de montar o socket do daemon Docker do host (`/var/run/docker.sock`), permitindo escape de contêiner e controle total do host em caso de comprometimento da aplicação.

---

6. Relatório Trivy Container Image Scan (Pipeline Dinâmica - Falha F2)

- **Alvo Analisado:** Imagem compilada `clube-aurora-api:local`
- **Origem da Evidência:** `logs_execucao/vulneravel/vuln_dynamic.md` , linhas 280 a 346
- **Extrato Real do Log:**

```
clube-aurora-api:local (debian 13.7)
====================================
Total: 2 (HIGH: 2, CRITICAL: 0)

Python (python-pkg)
===================
Total: 12 (HIGH: 12, CRITICAL: 0)


          Library           Vulnerability   Severity  Status  Installed Version  Fixed Version

 Werkzeug (METADATA)        CVE-2024-34069  HIGH      fixed   2.2.3              3.0.3           python-we
 gunicorn (METADATA)        CVE-2024-1135   HIGH      fixed   20.1.0             22.0.0          python-gu
 gunicorn (METADATA)        CVE-2024-6827   HIGH      fixed   20.1.0             22.0.0          gunicorn:
 jaraco.context (METADATA)  CVE-2026-23949  HIGH      fixed   5.3.0              6.1.0           jaraco.co
 urllib3 (METADATA)         CVE-2023-43804  HIGH      fixed   1.26.5             2.0.6, 1.26.17  python-ur
 urllib3 (METADATA)         CVE-2025-66418  HIGH      fixed   1.26.5             2.6.0           urllib3:
 urllib3 (METADATA)         CVE-2025-66471  HIGH      fixed   1.26.5             2.6.0           urllib3:
 urllib3 (METADATA)         CVE-2026-21441  HIGH      fixed   1.26.5             2.6.3           urllib3:
 urllib3 (METADATA)         CVE-2026-44431  HIGH      fixed   1.26.5             2.7.0           urllib3:
 urllib3 (METADATA)         CVE-2026-97687  HIGH      fixed   1.26.5             2.8.0           urllib3:
 urllib3 (METADATA)         CVE-2026-97689  HIGH      fixed   1.26.5             2.8.0           urllib3:
 wheel (METADATA)           CVE-2026-24049  HIGH      fixed   0.45.1             0.46.2          wheel: Pr

##[error]Process completed with exit code 1.
```

- **Diagnóstico Técnico:**
  A imagem Docker construída a partir do `python:latest` herdou 2 vulnerabilidades no sistema operacional base Debian e 12 vulnerabilidades HIGH nas bibliotecas Python, reprovando o contêiner no Quality Gate de imagem.

---

7. Relatório OWASP ZAP Baseline DAST (Falha F5 - Headers HTTP)

- **Alvo Analisado:** `http://localhost:8080` (Aplicação viva em execução)
- **Origem da Evidência:** `logs_execucao/vulneravel/vuln_dynamic.md`, linhas 532 a 541
- **Extrato Real do Log:**

```
FAIL-NEW: X-Content-Type-Options Header Missing [10021] x 4
    http://localhost:8080 (200 OK)
    http://localhost:8080/ (200 OK)
    http://localhost:8080/robots.txt (200 OK)
    http://localhost:8080/sitemap.xml (200 OK)
FAIL-NEW: Content Security Policy (CSP) Header Not Set [10038] x 1
    http://localhost:8080/admin (404 Not Found)
FAIL-NEW: 2 FAIL-INPROG: 0  WARN-NEW: 0 WARN-INPROG: 0  INFO: 0 IGNORE: 0   PASS: 59
##[error]Scan action failed as ZAP has identified alerts, starting to analyze the results. Error: The proc
```

- **Diagnóstico Técnico:**
  O ZAP testou ativamente as respostas HTTP emitidas pelo Flask e identificou a falta dos cabeçalhos defensivos `X-Content-Type-Options` (que protege contra MIME sniffing) e `Content-Security-Policy` (que mitiga XSS e injeção de recursos). Como as regras estavam mapeadas como falha obrigatória no `.zap/rules.tsv`, a esteira foi reprovada com `FAIL-NEW: 2`.

---

8. Falha F6: Quebra do Menor Privilégio e Falha de Autorização (RBAC)

- **Onde Inspecionar:** `aurora/app/db.py` (L58) e `aurora/app/main.py` (L92-94)
- **Causa Raiz no Código:**
  1. No banco de dados (`db.py`), a função `create_user` cria novos usuários com `role="admin"` por padrão.
  2. Na rota `/admin/users/<int:user_id>/role` (`main.py`), há apenas o decorador `@auth.login_required`, permitindo que qualquer usuário autenticado comum altere os privilégios de qualquer outro usuário.
- **Por que ferramentas automatizadas de scanner não apontam F6?**
  Scanners estáticos padrão identificam falhas de sintaxe e padrões conhecidos de injeção. Eles não possuem conhecimento do modelo de negócios do Clube Aurora para saber que um novo sócio cadastrado deveria possuir apenas permissão de leitura (`user`). Essa vulnerabilidade exige **Revisão Manual de Código (Code Review)** e **Modelagem de Ameaças (STRIDE)**.